

Information Systems Management

Chapter # 8

Securing Information Systems

Case Study Presentation

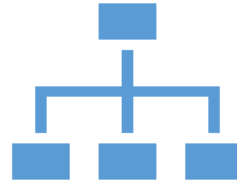
#1 and #2

Why Information Systems are Vulnerable?



Security

Policies, procedures, and technical measures used to prevent unauthorized access, alteration, theft, or physical damage to information systems



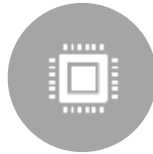
Controls

Methods, policies, and organizational procedures that ensure safety of organization's assets; accuracy and reliability of its accounting records; and operational adherence to management standards

Why Information Systems are Vulnerable?



Accessibility of networks



Hardware problems
(breakdowns, configuration
errors, damage from
improper use or crime)



Software problems
(programming errors,
installation errors,
unauthorized changes)



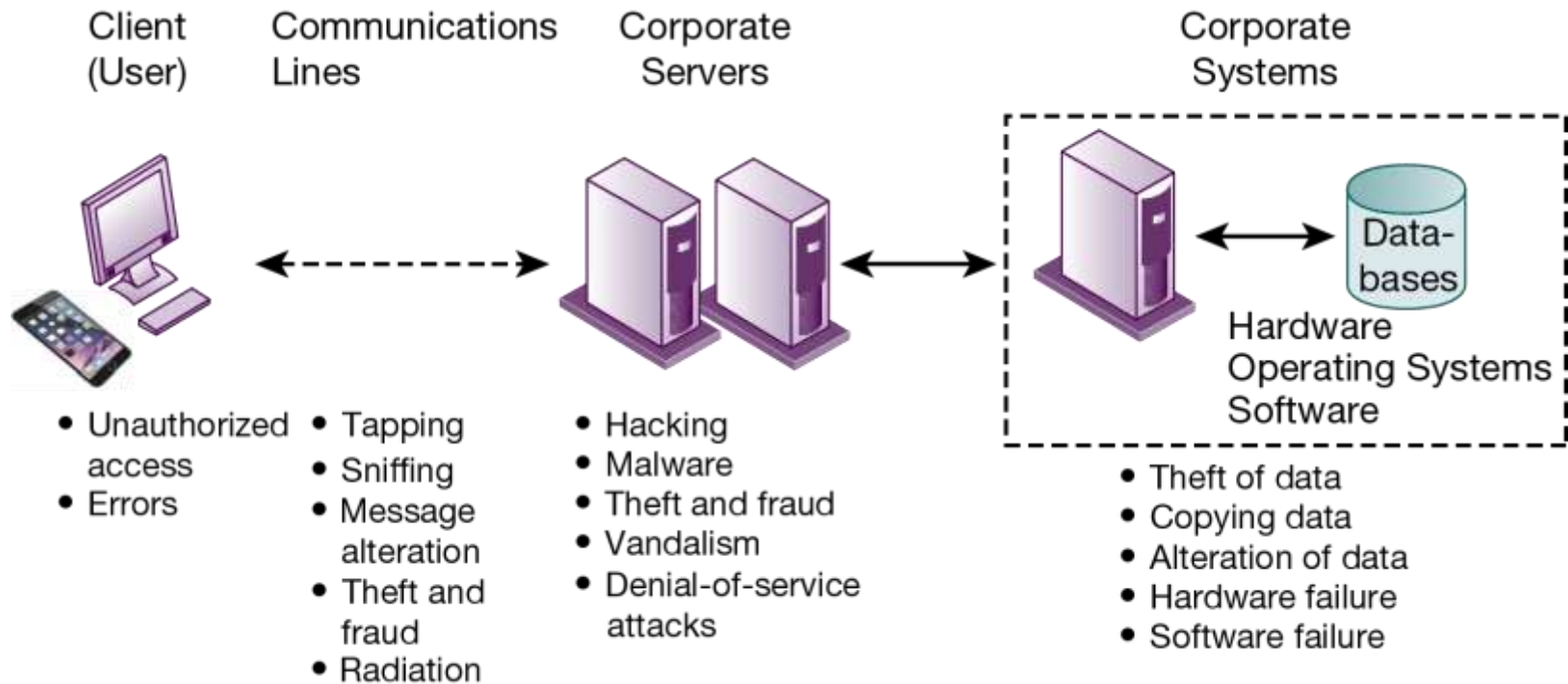
Disasters



Use of networks/computers
outside of firm's control



Loss and theft of portable
devices



Contemporary Security Challenges and Vulnerabilities

Internet Vulnerabilities



Network open to anyone; size means abuses can have wide impact



Corporate networks linked to Internet more vulnerable



E-mail, IM, and P2P increase vulnerability

Email: attachments with malicious software; can be used to transmit trade secrets, confidential data

IM: back door into a secure network

P2P: can transmit malicious software, expose corporate data

Wireless Security Challenges

Bluetooth and Wi-Fi networks susceptible to hacking

- Radio frequency bands easy to scan
- SSIDs (service set identifiers)
 - Identify access points, broadcast multiple times, can be identified by sniffer programs

War driving

- Eavesdroppers drive by buildings and try to detect SSID and gain access to network and resources
- Once access point is breached, intruder can gain access to networked drives and files

Rogue access points

Malicious Software: Viruses, Worms, Trojan Horses, and Spyware



Malware (malicious software)



Viruses



Worms



Worms and viruses spread by

Downloads and drive-by downloads

E-mail, IM attachments

Malicious Software: Viruses, Worms, Trojan Horses, and Spyware

- Mobile device malware
 - *Kaspersky lab reported there were 116.5 million malicious mobile malware attacks in 2018, double the number of previous year (Kaspersky Lab, 2019)*
 - *Android, which is the world's leading mobile operating system, is the mobile platform targeted by most hackers. Mobile device viruses pose serious threats to enterprise computing because so many wireless devices are now linked to corporate information systems.*
- Social network malware
 - *Spreading through hijacked social network accounts (communication is not legitimate)*

Malicious Code (some examples)

NAME	TYPE	DESCRIPTION
Cryptolocker	Ransomware/ Trojan	Hijacks users' photos, videos, and text documents; encrypts them with virtually unbreakable asymmetric encryption; and demands ransom payment for them.
Conficker	Worm	First detected in November 2008 and still a problem. Uses flaws in Windows software to take over machines and link them into a virtual computer that can be commanded remotely. Had nearly 10 million computers worldwide under its control. Difficult to eradicate.
Sasser.ftp	Worm	First appeared in May 2004. Spread over the Internet by attacking random IP addresses. Causes computers to continually crash and reboot and infected computers to search for more victims. Affected millions of computers worldwide and caused an estimated \$14.8 billion to \$18.6 billion in damages.
ILOVEYOU	Virus	First detected on May 3, 2000. Script virus written in Visual Basic script and transmitted as an attachment to email with the subject line ILOVEYOU. Overwrites music, image, and other files with a copy of itself and did an estimated \$10 billion to \$15 billion in damage.

Malicious Software: Viruses, Worms, Trojan Horses, and Spyware

Trojan Horse

- *An example of a modern-day Trojan horse is the ZeuS (Zbot) Trojan, which infected more than 3.6 million computers in 2009 and still poses a threat. It has been used to steal login credentials for banking by surreptitiously capturing people's keystrokes as they use their computers. Zeus is spread mainly through drive-by downloads and phishing, and recent variants have been difficult to eradicate.*

Malicious Software: Viruses, Worms, Trojan Horses, and Spyware

- SQL injection attacks

- *An attacker uses the input validation error to send a rogue SQL query to the underlying database to access the database, plant malicious code, or access other systems on the network.*

- Ransomware

- *In 2019, twenty-two Texas cities were held hostage for millions of dollars after ransomware called Sodinokibi infiltrated their computer systems and encrypted their data (Fruhlinger 2020).*

- Spyware

- Key loggers - *The Zeus Trojan described earlier uses keylogging*
 - Other types: Reset browser home page, Redirect search requests, Slow computer performance by taking up memory

Hackers and Computer Crimes

- Hackers vs Crackers
 - Activities include:
 - System intrusion
 - System damage
 - Cybervandalism
(Intentional disruption, defacement, destruction of website or corporate information system)
- Spoofing and sniffing

Hackers and Computer Crimes

- Denial-of-service attacks (DoS)
- Distributed denial-of-service attacks (DDoS)
- Botnets
- Spam

- Hackers create these botnets by infecting other people's computers with bot malware that opens a back door through which an attacker can give instructions to the infected computer. When hackers infect enough computers, they can use the amassed resources of the botnet to launch DDoS attacks, phishing campaigns, or unsolicited spam email.

Example

- Ninety percent of the world's spam and 80 percent of the world's malware are delivered by botnets.
- A recent example is the Mirai botnet, which infected numerous IoT devices (such as Internet-connected surveillance cameras) in October 2016 and then used them to launch a DDoS attack against Dyn, whose servers monitor and reroute Internet traffic. The Mirai botnet overwhelmed the Dyn servers, taking down Etsy, GitHub, Netflix, Shopify, SoundCloud, Spotify, Twitter, and a number of other major websites. A Mirai botnet variant attacked financial firms in January 2018, and Mirai variants are still active.

Computer Crime

- Computer crime defined by U.S. Department of Justice as “Any violations of criminal law that involve a knowledge of computer technology for their perpetration, investigation, or prosecution”.
- According to Accenture and the Ponemon Institute’s Ninth Annual Cost of Cyber Crime Study, the average annualized cost of cybercrime security for benchmarked organizations was U.S. \$13 million in 2018 (Accenture, 2019).
- Many companies are reluctant to report computer crimes. Why? What are the most economically damaging types of computer crime?

Breaching the confidentiality of protected computerized data

Accessing a computer system without authority

Knowingly accessing a protected computer to commit fraud

Intentionally accessing a protected computer and causing damage negligently or deliberately

Knowingly transmitting a program, program code, or command that intentionally causes damage to a protected computer

Threatening to cause damage to a protected computer

Computers as Target of Crime

Computers as Instruments of Crime

Theft of trade secrets

Unauthorized copying of software or copyrighted intellectual property, such as articles, books, music, and video

Schemes to defraud

Using email or messaging for threats or harassment

Intentionally attempting to intercept electronic communication

Illegally accessing stored electronic communications, including email and voice mail

Transmitting or possessing child pornography by using a computer

Hackers and Computer Crimes

- **Identity theft** - *According to the 2020 Identity Fraud Study by Javelin Strategy & Research, identity fraud losses in the United States reached \$16.9 billion in 2019 (Javelin, 2020).*
- **Phishing** – Creating fake websites, directing the traffic and capturing personal data
 - Spear Phishing : when messages come from trusted source
 - Evil twins (Bogus Wi-fi network)
 - Pharming (Redirects to the Bogus Webpage)

Hackers and Computer Crimes

- **Click fraud** : A serious problem at Google and other websites that feature pay-per-click online advertising)
- **Cyberterrorism**
- **Cyberwarfare**
 - Is a state-sponsored activity designed to cripple and defeat another state or nation by penetrating its computers or networks to cause damage and disruption.

Internal Threats: Employees

- Security threats often originate inside an organization
- Inside knowledge
- Sloppy security procedures
 - User lack of knowledge
- Social engineering
- Both end users and information systems specialists are sources of risk

Software Vulnerabilities



Commercial software contains flaws that create security vulnerabilities

Bugs (program code defects)

Zero defects cannot be achieved

Flaws can open networks to intruders

(In May 2019, Facebook had to fix it flaw in its Whatsapp Encrypted Messaging app that allows attackers to install spyware on mobile Phones)



Zero-Day Vulnerabilities



Vulnerabilities in microprocessor design: Spectre, Meltdown

Business Value of Security and Control

For example, **U.S. retailer Target** had to pay **\$39 million** to several U.S. banks servicing Mastercard that were forced to reimburse Target customers millions of dollars when those customers lost money due to a massive 2013 hack of Target's payment systems affecting 40 million people. Target also paid \$67 million to Visa for the data hack and \$10 million to settle a class-action lawsuit brought by Target customers.

Legal and Regulatory Requirements

- **HIPAA(Health Insurance Portability and Accountability Act)**
 - Medical security and privacy rules and procedures
- **Gramm-Leach-Bliley Act**
 - Requires financial institutions to ensure the security and confidentiality of customer data
- **Sarbanes-Oxley Act**
 - Imposes responsibility on companies and their management to safeguard the accuracy and integrity of financial information that is used internally and released externally

Components of an Organization Framework for Security and Control

- Information System Control
- Risk Assessment
- Security Policy
- Disaster Recovery Planning and Business Continuity Planning
- Role of Auditing

Case Study Presentation

#3 and #4

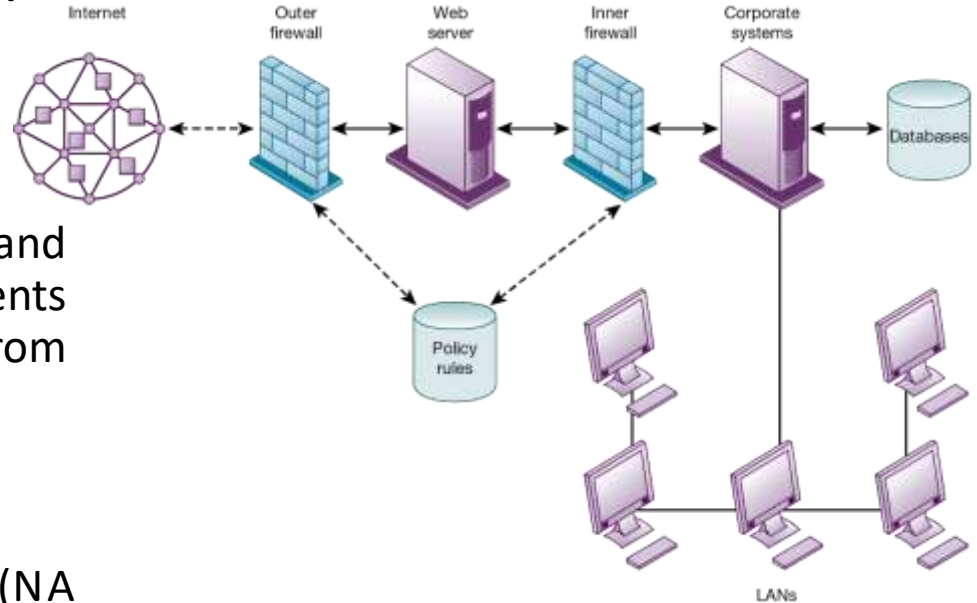
Tools and Technologies for Safeguarding Information Systems

- **Identity management software**
 - Automates keeping track of all users and privileges
 - Authenticates users, protecting identities, controlling access
- **Authentication**
 - Password systems
 - Tokens
 - Smart cards
 - Biometric authentication
 - Two-factor authentication

Tools and Technologies for Safeguarding Information Systems

Firewall

- Combination of hardware and software that prevents unauthorized users from accessing private networks
- Packet filtering
- Stateful inspection
- Network address translation (NAT)
- Application proxy filtering

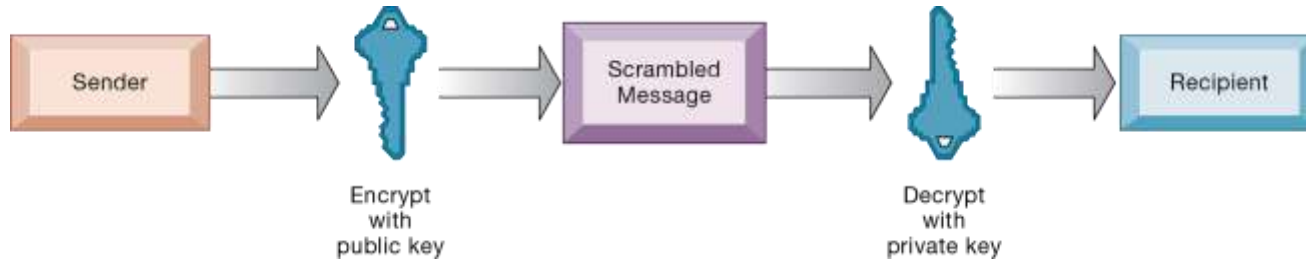


Tools and Technologies for Safeguarding Information Systems

- **Intrusion detection system**
 - Monitors hot spots on corporate networks to detect and deter intruders
- **Anti-malware and anti-spyware software**
 - Checks computers for presence of malware and can often eliminate it as well
 - Requires continual updating
- **Unified threat management (UTM) systems**

Securing Wireless Networks

- **WEP security**
 - Static encryption keys are relatively easy to crack
 - Improved if used in conjunction with VPN
- **WPA2 specification**
 - Replaces WEP with stronger standards
 - Continually changing, longer encryption keys
- **WPA3** is most recent specification, with even stronger encryption.

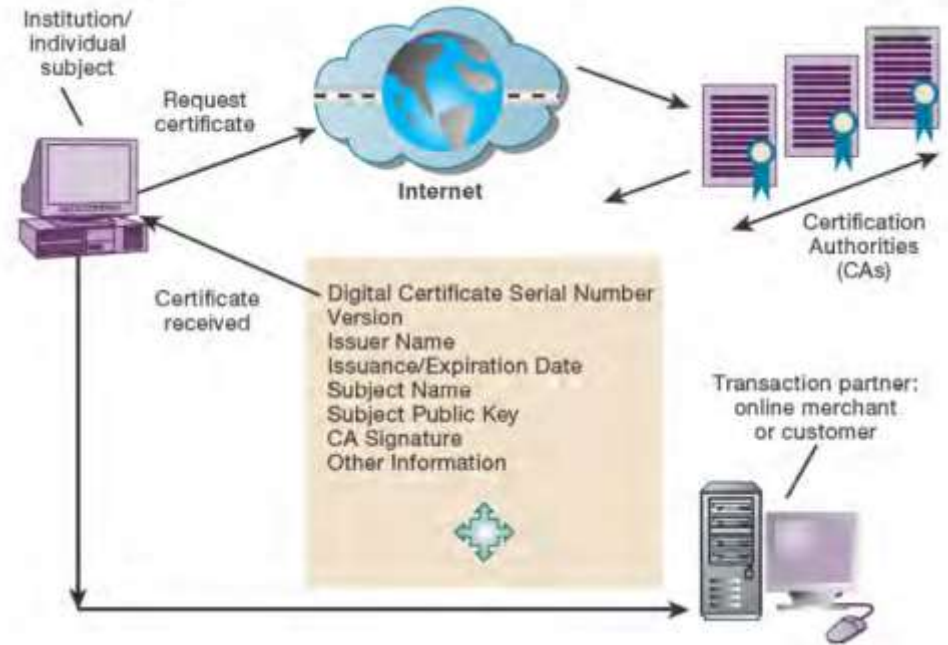


- Process of transforming plain text or data into cipher text that cannot be read by anyone other than the sender and the intended receiver.
- **SSL** : To establish a secure connection between two computers
- **S-HTTP** : For data flowing over the Internet, but it is limited to individual messages only.

Encryption & Public Key Infrastructure

Digital Certificates

- Used to establish identity of users and electronic assets for protection of online transactions
- Agencies which issues these certificates



Securing Transactions with Blockchain



SECURE TRANSACTION
DATABASE



ENCRYPTION USED TO
VERIFY USERS AND
TRANSACTIONS



DECENTRALIZED



RECORDS CANNOT BE
CHANGED



BLOCKCHAIN HAS SOME
VULNERABILITIES
REQUIRING ATTENTION
TO SECURITY AND
CONTROLS

Security Issues for Cloud Computing and the Mobile Digital Platform

Security in the cloud

- Responsibility for security resides with company owning the data
- Firms must ensure providers provide adequate protection:
 - Where data are stored
 - Meeting corporate requirements, legal privacy laws
 - Segregation of data from other clients
 - Audits and security certifications
- Service level agreements (SLAs)

Security Issues for Cloud Computing and the Mobile Digital Platform

- **Securing mobile platforms**
 - Security policies should include and cover any special requirements for mobile devices
 - Guidelines for use of platforms and applications
- **Mobile device management tools**
 - Authorization
 - Inventory records
 - Control updates
 - Lock down/erase lost devices
 - Encryption
- Software for segregating corporate data on devices